

Resenha – Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions

"Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions" é um artigo acadêmico escrito por Xinyi Hou, Yanjie Zhao, Sheno Wang e Haoyu Wang, todos da Universidade de Ciência e Tecnologia de Huazhong, na China, publicado na ACM Transactions on Software Engineering and Methodology em 2026. O objetivo do texto é fazer a primeira análise abrangente do ecossistema do MCP, cobrindo sua arquitetura, ciclo de vida, adoção no mercado e, principalmente, os riscos de segurança que ele apresenta. É um artigo extenso e denso, mas que se justifica pela relevância do tema num momento em que o MCP está crescendo de forma muito rápida na indústria de IA.

O ponto de partida dos autores é explicar o problema que motivou a criação do MCP. Antes dele, cada aplicação de IA precisava integrar cada ferramenta externa de forma manual, com APIs específicas, autenticação própria e código de cola escrito na mão para cada caso. Isso tornava os sistemas frágeis, difíceis de manter e limitados a integrações predefinidas. O MCP, lançado pela Anthropic em 2024, surge como um protocolo aberto e padronizado que define como modelos de linguagem se comunicam com ferramentas e recursos externos. Diferente das abordagens anteriores, ele suporta descoberta dinâmica de ferramentas, canais de comunicação bidirecionais e controle de acesso como parte nativa do protocolo, o que o posiciona como algo bem mais robusto do que um simples mecanismo de chamada de função.

Na parte arquitetural, o artigo detalha os três componentes centrais do MCP: o host, que é a aplicação que o usuário usa diretamente (como o Claude Desktop ou o Cursor); o client, que gerencia a comunicação dentro do host; e o server, que é o componente que expõe as ferramentas e recursos para o modelo. Os autores também propõem um modelo de ciclo de vida do servidor MCP dividido em quatro fases, sendo criação, implantação, operação e manutenção, com 16 atividades específicas mapeadas ao longo dessas fases. Essa decomposição é uma das contribuições mais originais do trabalho, pois serve de base para toda a análise de segurança que vem depois.

A seção de segurança é o coração do artigo. Os autores constroem uma taxonomia de ameaças que identifica quatro tipos de atacantes: desenvolvedores maliciosos, que criam servidores com intenção de enganar; atacantes externos, que tentam comprometer servidores legítimos; usuários maliciosos, que exploram as ferramentas para fins não autorizados; e falhas de segurança, que são vulnerabilidades sem intenção clara de ataque. No total, são mapeados 16 cenários de ameaça, com casos reais demonstrando como ataques como typosquatting de namespace, envenenamento de ferramentas, injeção indireta de prompt e roubo de credenciais funcionam na prática. Um dos exemplos mais interessantes é a criação de dois servidores com nomes visualmente parecidos, github-mcp e mcp-github, em que o modelo de IA não conseguiu distinguir o legítimo do malicioso, resultando em exfiltração de tokens de autenticação.

Com base nesses riscos, o artigo propõe salvaguardas específicas para cada fase do ciclo de vida. Na criação, recomenda validação de namespace e assinaturas criptográficas. Na implantação, defende verificação de identidade e mecanismos de reputação. Na operação, sugere monitoramento de intenção e sandboxing ativo. Na manutenção, foca em controle de versão estruturado e auditoria contínua. A lógica de vincular cada recomendação à fase em que o risco se manifesta é bem executada e torna o conteúdo mais aplicável do que guias genéricos de segurança.

O artigo também analisa o ecossistema atual do MCP, mapeando plataformas como MCP.so, Glama e PulseMCP, além de SDKs oficiais em TypeScript, Python, Java, Kotlin e C#. Os autores reconhecem que o crescimento é rápido, mas apontam que a qualidade dos servidores disponíveis publicamente é bastante irregular, com muitos listados sem verificação real de identidade ou segurança.

O ponto forte do trabalho é a abrangência: ele cobre arquitetura, adoção, ameaças e mitigações num único lugar, com casos reais e dados coletados diretamente do ecossistema. A limitação mais clara é que, por ser um campo muito novo, algumas análises são necessariamente preliminares e os dados podem envelhecer rápido. No geral, é uma leitura essencial para quem trabalha ou quer trabalhar com sistemas de IA agênticos, especialmente num momento em que o MCP começa a se estabelecer como padrão da indústria.